隐盾安全智能体 • 使用说明

> 面向涉密办公场景的本地化隐私防护桌面智能体 · V3.5.0 Yindun Security Agent — 让本地 AI 更安全、更智能、更可控

一、产品简介

隐盾安全智能体是一款常驻桌面的 AI 办公助手，核心差异在于**内置内存级隐私防护**： 所有敏感信息（手机号、身份证、银行卡、密钥、病历、金额、人名等）在进入大模型之前， 会在内存中自动替换为加密占位符；模型全程只见占位符，回答返回时再自动还原为明文呈现给你。

配合文件沙箱、权限分级、命令白名单、高危操作人工审批与哈希链审计， 隐盾把"数据出网、落盘、留痕"三大泄露面逐一关闭，让你放心把涉密文档交给 AI 处理。

典型用途：合同/简历/病历等涉密文档的问答与摘要、本地知识库检索、 项目代码分析、办公文件创建与整理、可追溯的操作审计。

二、安装与启动

> 界面说明：V3.3.2 起隐盾使用 Web 界面（窗口无系统边框，**拖动顶部条即可移动窗口**、**沿窗口边缘拖拽可改变大小**， 右上角有最小化 / 置顶 / 关闭）。左侧是会话列表，中间是对话区，右侧是**可折叠的第三栏** （设置 / 审计 / 工作流三个页签）；顶栏两侧各有一个折叠按钮，收起后把空间让给对话。
>
> **三栏宽度可以自由调**：把鼠标移到会话栏右边缘或面板左边缘（会出现一条细高亮线），按住拖动即可改变该栏宽度；**双击手柄**恢复默认宽度；手柄获得焦点后可用方向键微调（按住 Shift 步长更大）。宽度会自动记住，下次打开还是你调好的样子。范围上做了保护： 会话栏 200–420px、面板 300–640px，且**对话区始终保留至少 420px**——窗口变窄时优先收窄两侧， 再窄就自动把右栏收起来（窗口重新变宽会自动放回，这与"你自己手动收起"是两回事，手动收起不会被自动展开）。
>
> **闪发浮条（折叠模式）**：点顶栏的折叠按钮，窗口会缩成一条浮条（贴着原窗口底边、水平居中）。 在浮条里输入指令按回车，会**自动展开完整界面并把指令发出去**；按 `Shift+Enter` 则是**换行不发送** （浮条输入框最多显示两行，再多就在框内滚动）；浮条右侧常显一行状态 （推理中…/已完成），不展开也知道有没有在跑；点浮条左侧的展开按钮或按 `Esc` 即可还原完整界面， 窗口会精确回到折叠前的位置与大小。适合"只想顺手发一句、不想让窗口占地方"的场景。 **草稿不会丢**：主输入框里打好的字在折叠后会跟着进浮条，折叠期间在浮条里打的字在展开后会回到主输入框； 模型正在推理时按回车也不会吞掉你打的字，只会提示"正在推理中"。
>
> **置顶（悬浮于最上层）立即生效**：点右上角的置顶按钮或设置里的「窗口始终置顶」开关， 马上生效，不需要重启。

方式 A：免安装单文件 exe（推荐，双击即用）

1. 拿到 `Yindun-Portable-v3.5.0.exe`（约 130MB，单文件；从 GitHub Release 下载时为此名——资产名不支持中文；本地自行构建时产物名为 `隐盾安全智能体_V3.5.0_便携版.exe`）；
2. **双击直接运行**——无需安装、无需任何脚本、不需要管理员权限；
3. 首次启动约需 10~20 秒（单文件会先解压到临时目录，属正常现象），之后正常速度。

数据落在哪：配置、会话记录、审计日志、知识库向量数据都写在 **exe 同目录**，所以请把 exe 放在可写目录（桌面、文档、便携盘均可）。 **卸载**：删除 exe 及其同目录下生成的数据文件即可，不留残余。

方式 B：源码运行（开发者）

```
# Python 3.10+，安装依赖
pip install -r requirements.txt
python run.py
```

> 首次启动若被杀毒软件 / Windows Defender 提示，选择"仍要运行"或添加信任即可（未签名的绿色软件常见误报，源码可自查）。

三、首次使用：配置一个"算力底座"

隐盾需要接入一个大模型作为算力底座。**设置按"数据边界"分成三档**——本机 / 局域网 / 公网， 你随时能看出"这个模型会把数据带到哪里去"：

档位	数据边界	典型形态
本机模型	数据不出这台电脑	本机跑的 Ollama（127.0.0.1:11434）
局域网模型	数据出这台电脑，但不出企业内网	公司内网的推理服务 / Ollama（10.x / 192.168.x）
公网模型	数据出企业内网；送出前内容已在本机脱敏	云端 OpenAI 兼容接口（https://.../v1）

入口：点左下角**齿轮**图标 → 顶栏「**模型接入**」页（左边是三档供应商列表，右边是选中项的配置表单）。

方式 A：本机模型（推荐，数据全程不出机器）

1. 下载安装 Ollama：https://ollama.com/download（安装后服务自动运行）；
2. 命令行拉取一个支持工具调用的模型，需要知识库再拉向量模型：`bash ollama pull qwen3.5:4b ollama pull nomic-embed-text`
3. 回到「模型接入 → 本机模型」，点「重新检测」——检测到的模型会列出来，**点一下就切换**。

方式 B：局域网模型（公司内网的推理服务）

1. 「模型接入 → 局域网模型」→ 点「+ 添加局域网模型」；
2. 填 **显示名称 / 模型 ID / 接口地址**（如 `http://10.0.0.8:8000/v1`），内网通常不需要 Key；

3. 点「**测试连接**」——通了会显示该端点提供的模型名，并可自动补进"模型 ID"；再点「保存」。

> 探测是你在这页**显式发起**的动作：地址只取自输入框、不跟随重定向、4 秒超时、只读模型列表。

方式 C：公网模型（云端 API）

1. 「模型接入 → 公网模型」→「+ 添加公网模型」；
2. 填名称 / 模型 ID / 接口地址 / API Key，先「测试连接」再「保存」。 示例（智谱开放平台）：`https://open.bigmodel.cn/api/paas/v4` + `glm-4-flash`；
3. 保存后在输入框下方的**模型胶囊**里选择它。

> **隐私提示**：开启"隐私隔离网关"（默认开启）时，发往公网的内容已在本机替换为占位符， 真实敏感数据不出机器；密钥加密存本机、界面不回显。

切换模型

输入框**下方那一行**就是会话级设置（参考主流 agent 的输入区布局）：`＋ 挂载文档 · 模型胶囊 · 思考强度 · 发送`。点模型胶囊会按三档分组列出可用模型； 思考强度是**四档**（低 / 中 / 高 / 最高，对应推理轮次约 2 / 4 / 7 / 10），点一下即生效。 换模型、换档位都立即生效，正在跑的轮次不受影响。

四、核心功能使用

4.1 对话与隐私脱敏

直接在底部输入框下达指令即可。含敏感信息的内容会先脱敏再交给模型，回答后自动还原。

- **快速 / 思考模式**：输入框上方切换。快速模式为只读安全模式（禁止一切写盘/删除/命令执行）； 思考模式支持完整工具调用与多轮推理（推理强度在输入框下方的「思考」四档控件里随手调：低 / 中 / 高 / 最高）。快速模式同样支持多轮工具调用，只是不强制深化。
- **AI 权限四档**：设置页「隐私与权限 → AI 权限模式」，四档配一张能力对照表（读取一律放行，差别只在写盘 / 删除 / 执行命令）。 计划模式只读分析、不做任何变更；变更前确认为默认档（写盘 / 删除 / 命令前逐次确认）；自主模式在沙箱内自动写盘、删除与命令仍需确认； 完全访问在沙箱内连删除也自动放行。★ **执行命令在任何档位都需要你确认**，系统目录

与凭据文件（`.ssh` / `.aws` / `.env` / `id_rsa`）的拦截与档位无关。 切换档位**下一个操作就生效**，不需要重启。

- **严格模式（可选，收紧命令执行）**：设置页「隐私与权限 → 允许执行本地脚本」关闭后，命令执行禁用 Python 等解释器，仅保留只读命令（git 只读 / echo）；需要跑脚本的办公流程再打开。 无论开关如何，命令都在进程容器内执行（超时会终止整棵进程树），且每次执行仍需人工审批。
- **挂载文件**：点" 挂载文件"上传 PDF / Word / Excel / TXT 等，直接在对话中就其内容提问。
- **会话管理**： 切换历史会话， 新建会话；多会话相互隔离，记录加密存储。

4.2 本地知识库（脱敏 RAG）

在设置页底部"本地知识库"区，点" 添加文档"将机密文档入库（入库即逐块脱敏， 向量库中只存占位符，真实隐私永不落盘）。之后在对话中即可语义检索问答。

4.3 协同工作流

点左下角工作流图标进入工作流编排，内置合同审查 / 周报生成 / 代码安全检查等模板， 支持步骤执行、审批通过与人工拦截；标记为「演示步骤」的环节目前返回模拟结果（界面已如实标注）。

- **实例重启不丢**：执行到一半（包括"等待人工审批"）的实例会自动保存，重启应用后原样恢复， 可以接着审批、继续执行；执行中的步骤若因重启中断，会回到"待执行"而不是卡死。
- **周报数据真实**："收集工作记录"步骤读的是**真实审计日志**，审计为空就如实说为空， 不再编造示例记录凑内容。
- **导出格式如实**：工作流报告可导出 Markdown / HTML / Word（兼容格式）/ JSON， 以及插件提供的格式；不支持的格式（如 PDF）会明确报错并说明支持哪些， 不会出现"步骤叫导出 PDF、产物却是 Markdown"的情况。

4.4 审计黑匣子

点左下角审计图标打开审计黑匣子：LLM 输入输出、工具调用、脱敏还原、审批决策逐条留痕， 哈希链完整性状态实时可见，可导出 JSON / HTML 审计报告；面板内还提供「隐私健康体检」与「模型行为画像」。 启用「导出格式扩展」插件后，导出菜单还会多出"Markdown 表格 / 卡片式 HTML"两种格式（菜单里会标明来源）。

关于"链校验未通过"：校验未通过时面板会直接写出**原因**（例如"尾部被截断""锚点缺失" "第 N 条出现未受保护的旧版条目"），不是只给一个红叉。若原因是**锚点缺失**——通常出现在 从旧版本升级、或把审计目录拷到另一台机器之后——面板会给出「重建锚点（接受当前链）」按

钮： 点它表示**你确认接受当前这份链作为新的信任起点**；确认之后，此前发生的尾部截断将无法再被发现， 所以请先确认这份链确实没有被裁剪过再点。

4.5 插件（按需扩展能力）

设置页「插件（能力扩展）」区列出内置与用户安装的插件，默认全部关闭，需要时打开开关即可。 每个插件卡片会写清：**它提供了什么能力**、来源（内置/用户安装）、网络/文件权限、依赖是否满足。

怎么确认插件真的在工作（三个证据，卡片里直接可见）：

1. **运行状态行**（卡片顶部）： 显示"已触发 N 次 · 最近时间 · 正常/出错"。 - `等待触发` = 已启用但还没遇到对应场景（如"审批决策提示"要等审批弹窗出现才运行）； - `未启用` = 开关没打开； - `出错：…` = 最近一次运行失败，原因直接写在卡片上。

   > 说明：运行状态只统计"实际被调用过"的次数——不写日志、不猜，有没有干活一眼可见。

2. **效果证据**：插件生效时结果会出现在具体位置——审批弹窗里的提示行（标注了插件名）、导出菜单里的插件格式、工作流模板列表里的"插件"来源标注。
3. **审计记录**：启用/停用与配置改动都会写入审计页，可随时回溯。 如果怀疑"启用了却没反应"，点「插件自检」——钩子函数缺失这类问题会被直接报出来。

- **自定义敏感词表**：把项目代号、内部称谓、专用术语纳入脱敏。编辑词表文件，每行一条：普通词按字面匹配，`re:` 开头按正则，`#` 开头是注释。命中后送模型的是占位符，还原仍只在本机完成。
- **扩展附件解析**：让 `.eml` / `.html` / `.mht` 也能当附件挂载（纯标准库解析，不联网）， 解析出的文本与内核路径一样先脱敏再送模型。
- **办公工作流模板包**：给工作流补两个模板（代码安全体检增强版 / 本周工作总结）。 其中"导出报告"这类高危步骤的审批由**内核强制**，插件无权降低审批强度。
- **导出格式扩展**：审计报告导出 Markdown 表格、工作流报告导出卡片式 HTML。
- **审批决策提示**：审批弹窗出现后，用本地模型判断"这次操作与你刚才的请求是否相符"，结论异步补发到弹窗，仅供参考。
- **laya 风险分级**：审批弹窗再补一行风险分级（高危/中危/低危）。 **接入三步**：① 命令行 `pip install laya`（约 2~3GB，含 torch；仅源码运行模式可接入， 打包版 exe 因环境隔离无法加载，会自动使用正则回退）； ② 设置页打开该插件开关； ③ 首次触发会联网从 Hugging Face 下载模型权重（涉密环境请预先离线导入）， 下载期间插件只等 25 秒就先

用正则规则给出提示，权重就绪后自动切换为模型打分。 没装 laya 也完全可用——自动回退到正则规则分级，默认规则开箱自带，`risk_rules.txt` 可在设置页直接编辑、改动立即生效；`backend.txt` 可强制只用模型或只用正则。 无论哪条路径，提示都写明本次来源。

安全说明：插件是**本地代码**，隐盾不会联网下载插件（laya 是你要自己安装的第三方 Python 包）；启用/停用、词表改动都会写入审计。

> 想自己写插件？见 插件开发.md：钩子契约、安全边界与最小示例都在里面。

4.6 企业控制面（员工机自助接入 + 管理员集中管控）

员工侧（三步，不需要管理令牌）：向 IT 要一个 **6 位配对码** → 「设置 → 企业控制面」填 控制面地址 + 配对码 → 点「接入」，然后打开"上报"开关并（可选）打开"定时同步"。 接入后本机只上传**掩码事件与元数据**；控制面下发的策略**只收紧**，已生效的规则会逐条列在这页， 也可以显式撤销。断开上报**不会**自动移除已下发的规则（避免"悄悄放松"）。

控制台侧：顶栏「配对码」生成一次性码；端点表显示**在线/失联**与**策略待同步**； 「导出 CSV」把掩码审计导出来（合规留档，Excel 直接打开）。

对话流里看得见过程：思考（带耗时）、工具动作（名称/目标/结果）、以及**关键判定**—— 隐私隔离网关识别了哪些实体、laya 风险分级的结论等，都直接显示在对话流里，不只在审批弹窗一闪而过。

4.6 控制面（企业侧集中管理，运维用）

给 IT/安全管理员用，普通使用者不需要碰。**默认关闭**——集中管理是显式选用的能力，程序绝不静默上报。

在管理机上启动控制面：

```
python -m yindun.control.server --port 8787      # 默认只监听 127.0.0.1
```

启动后终端会打印监听地址与数据目录；**管理令牌**在 `control_data/admin_token.txt`（数据库里只存哈希）。 浏览器打开 `http://127.0.0.1:8787/`，粘贴令牌即可进入集中控制台（令牌只留在当前标签页，关闭即清除）。

控制台五页：**态势总览**（在管端点 / 事件总量 / 高危事件 / 链告警 + 链锚定状态 + 告警流）、**事件台账**（按端点/类型/级别/关键词检索）、**端点资产**（版本、链长、模型、插件、严格模

式、生效策略）、 **策略下发**（只提供"收紧"语义的四类输入）、**模型用量**（调用计数与交互体量，不含内容）。 支持明暗双主题、10 秒自动刷新、 `/` 聚焦搜索、 `1` ~ `5` 切页、 `R` 刷新。

在员工机器上接入（端点侧）：

1. 在控制台所在机器上登记端点（需要管理令牌），拿到**端点令牌**与**策略签名密钥**：

```
bash curl -X POST http://<控制面>:8787/api/v1/enroll \ -H "Authorization: Bearer <管理令牌>" -H "Content-Type: application/json" \ -d '{"name":"财务部-27号机","endpoint_id":"ep-fin-27"}'
```

2. 把返回的两个值写入端点配置并启用（`ControlReporter.configure(url, endpoint_id, token, policy_key)`； 令牌会加密落盘）。此后每次上报成功或失败都会写入**本地审计**（事件类型 `control_report`）， 使用者可在审计面板看到"什么离开了这台机器"。

三条边界（选它之前请先读）：

- **控制面拿不到明文**：它收到的内容 = 端点本地审计落盘的内容（敏感路径已掩码为占位符）； 映射密钥由端点 DPAPI 托管，控制面即便拿到映射表也解不开；模型提示词与回答从不经过控制面。
- **策略只能收紧，不能放行**：可下发项只有 敏感路径（并集）/ 审批下限（取更严）/ 允许的模型与插件（交集）/ 强制严格模式； `anonymize` 、 `bypass` 、 `auto_approve` 、 `whitelist` 、 `disable_audit` 这类键会被**整包拒绝**——端点被攻破最多让端点管得更严，放行不了任何操作。
- **不是系统级 DLP**：只覆盖隐盾自己经手的文件与命令事件，不监控整机行为；也不代理模型流量。

> 现状声明：这是**演示级原型**——默认只监听回环、单一管理令牌、无多租户与 TLS、无速率限制， 端点侧也还没有定时上报调度器。要对内网正式提供服务，请先补上 TLS 反向代理与来源限制。

五、安全机制说明

机制	作用
隐私脱敏网关	27 类敏感实体识别（正则粗筛 + 程序化精验），进模型前占位符化，映射表 Fernet 加密、密钥 DPAPI 保护
文件沙箱	所有文件操作限定在沙箱目录内，越界读写一律拒绝
权限四档	计划模式 / 变更前确认 / 自主模式 / 完全访问：只决定「要不要人工确认」，**不决定底线**——执行命令四档皆需确认（计划模式拒绝）、系统目录 deny 与凭据路径 confirm 与档位无关、控制面与自定义规则只能更严
命令白名单	放行 python/pip/git/echo，去 shell 化执行，并做子命令级收口：python 仅允许执行**沙箱内**的 .py 脚本（`-c` / `-m` /标准输入等内联代码一律拒绝；脚本路径经 realpath 校验，符号链接/盘符相对路径等越界形态拒绝；子进程只保留基础环境变量）；pip/git 仅允许只读子命令；审批弹窗会展示脚本内容预览，供放行前核对。命令在**进程容器**内执行（Windows Job Object：超时/应用退出即终止整棵进程树，进程数上限 64），并可在设置页开启严格模式直接禁用解释器。**边界说明**：这是策略层控制 + 进程容器，不是完整 OS 级沙箱——放行的脚本仍以当前用户权限运行
熔断审批	高危操作挂起后台线程，弹窗展示申请工具、目标路径与即将执行的命令 / 即将写入的内容，人工二次确认后才放行；超时自动驳回
哈希链审计	HMAC-SHA256 链式存储，篡改即告警；另设 HMAC **链锚点**（条数+链头，存放于密钥旁的用户目录）以发现"整链改写"与"尾部截断"；审计自身只存脱敏预览

六、数据与隐私

- **控制面（可选，默认关闭）**：`control_data/`（控制面自己的数据：SQLite 库、管理令牌明文文件）。 端点的上报配置在 `config/control.json`，其中令牌与策略签名密钥**加密落盘**。 ⚠ 启用前请确认数据边界：控制面看到的内容**等于端点本地审计落盘的内容**（敏感路径已掩码）， 映射密钥始终留在端点（DPAPI 绑定），控制面**无法还原明文**；模型提示词与回答**不经过控制面**。
- **配置**：程序目录下 `global_config.json`（模型、权限、界面等；免安装版即 exe 同目录）。
- **会话**：`chat_sessions.json`，内容加密存储；附件全文同样以密文段存储，**删除会话即连同其附件快照一并清除**（启动时也会把历史遗留的明文会话主动重写为加密存储）。
- **审计**：`audit_logs/`，哈希链防篡改，仅存脱敏预览。
- **知识库**：`data/knowledge_base/`，只存占位符向量（元数据只留文件名，不写本机路径）。
- **用户目录**（`%APPDATA%\Yindun\`）：只有两样东西——脱敏主密钥（Windows DPAPI 按当前用户保护） 与**审计链锚点**（`audit_chain.anchor.<审计目录指纹>.json`，用于发现"整链改写/尾部截断"）。 这两样刻意放在用户目录而不是程序目录：**不能与它们要保护的数据同盘**，否则"删掉密钥/锚点" 就能绕过保护。也因此它们不随 exe 移动（换机器后旧审计链需要重新确认，见 4.4）。
- 免安装版：删除 exe 与其同目录生成的数据即可；如需彻底清除，再删除上述用户目录下的 `Yindun\` 文件夹。 安装版：卸载即清除程序目录数据，用户目录同上。

七、常见问题（FAQ）

- **状态栏显示"模型初始化失败"**：未装 Ollama 或未拉取模型，按第三节方式 A 完成，或改用方式 B。
- **杀毒软件报警**：未签名绿色软件常见误报，添加信任即可。
- **想让 AI 写文件却提示"快速模式无法执行"**：切到"思考"模式再试。
- **回答里出现 `[PHONE_0_xxxx]` 这类占位符没还原**：属跨轮历史占位符，正常会随会话映射还原； 若长期不还原，可在设置页关闭再开启"隐私隔离网关"重置会话。
- **换了电脑/重装系统后旧会话无法还原明文**：脱敏密钥绑定 Windows 用户账户（DPAPI），属安全优先于可恢复性的既定设计。

八、版本与声明

- 当前版本：**V3.5.0**（技术栈 Python · LangChain · pywebview/WebView2 · Chroma · Ollama；Qt 已移除）
- 插件体系：内核不可插件化（脱敏 / 审批 / 审计 / 沙箱），能力可插件化（识别 / 解析 / 模板 / 导出）， 插件只能"做加法"；详见 插件开发.md。
- 本文档中出现的个人信息（张伟 / 13812345678 等）均为虚构测试样例，不涉及任何真实个人数据。